

DOCUMENTAÇÃO TÉCNICA · ALTERAÇÃO DOCUMENTADA

Autenticação, sessão JWT e logout

Do acesso local por nome e CPF para login por credenciais verificadas no servidor

Comparação: commit 2fe92e8 (HEAD) x staged files x working tree

Branch: main

Data da análise: 31 de julho de 2026

Arquivos principais: src/app/login/*; src/app/api/auth/*; src/lib/auth.ts; src/lib/user-validation.ts; core/infra/store/userStore.ts

Resultado: o login valida e-mail e senha no banco, cria sessão assinada por oito horas e protege as páginas pelo servidor.

Antes

A tela solicitava nome e CPF, validava o CPF no cliente e gravava ambos no localStorage. A navegação para o dashboard dependia apenas desse estado local; não havia senha, banco, cookie de sessão ou confirmação de identidade pelo servidor.

Agora

Aspecto	Antes	Agora
Identificador	nome + CPF	e-mail
Credencial	nenhuma	senha comparada com bcrypt
Estado de autenticação	localStorage	JWT em cookie HTTP-only
Validade	sem expiração	8 horas
Proteção	hook no cliente	guards no servidor
Saída	link para /login	POST /api/auth/logout + remoção local

Fluxo do login

1. Normalizar o e-mail e validar o corpo com Zod.
2. Buscar o usuário e sua permissão pelo e-mail.
3. Comparar a senha enviada com o hash bcrypt persistido.

4. Assinar JWT HS256 contendo o id no subject e expiração de oito horas.
5. Gravar sacflow_session como cookie HTTP-only, SameSite=Lax e Secure em produção.
6. Retornar dados sem a senha; atualizar nome/CPF locais para compatibilidade visual.

```
LoginForm -> POST /api/auth/login -> Prisma -> bcrypt.compare  
-> createSession -> cookie assinado -> /dashboard
```

Leitura da sessão

- getSessionUserId verifica assinatura, algoritmo e subject numérico.
- getCurrentUser consulta novamente o banco, portanto exclusão e mudança de permissão passam a valer na próxima leitura.
- requireAuthenticatedUser redireciona sessões ausentes ou inválidas para /login.
- destroySession remove o cookie; o sidebar também limpa nome e CPF do localStorage.

Pontos de segurança

- SESSION_SECRET é obrigatório e deve possuir pelo menos 32 caracteres.
- Não há limitação de tentativas, atraso progressivo, bloqueio ou auditoria de login.
- A sessão é stateless: não existe lista de revogação; a consulta ao usuário reduz o impacto de contas excluídas.
- Nome e CPF ainda são copiados para localStorage, embora não sejam mais a fonte de autorização.